Unit 3: Privacy in Big Data Analytics — Assignment Questions & Answers

Q1. Explain the Fair Information Practice Principles (FIPPs) and OECD Privacy Guidelines with suitable examples. (6 Marks)

Privacy models and principles provide the foundational framework that laws and organisational policies build upon when handling personal data.

Fair Information Practice Principles (FIPPs)

FIPPs are a set of widely accepted principles that guide the collection and use of personal information. Key principles include:

- **Notice/Awareness:** Individuals must be informed that their data is being collected before it happens. Example: a website's privacy policy displayed before signup.
- **Choice/Consent:** Individuals must be given the option to consent to or opt out of data collection and secondary uses.
- **Access/Participation:** Individuals should be able to view and correct their own data. Example: a user editing their profile information on a social media platform.
- **Integrity/Security:** Data collectors must ensure data is accurate and protected from unauthorised access.
- **Enforcement/Redress:** There must be mechanisms to enforce these principles and remedy violations.

OECD Privacy Guidelines

The OECD Guidelines on the Protection of Privacy (1980, updated 2013) are internationally recognised principles that influenced most modern privacy laws, including:

- **Collection Limitation:** Data should be collected lawfully and with the knowledge/consent of the individual.
- **Purpose Specification:** The purpose of data collection must be specified at the time of collection, and use limited to that purpose.
- **Data Quality:** Data should be accurate, complete, and kept up to date.
- **Security Safeguards:** Reasonable security measures must protect data against loss or unauthorised access.
- **Accountability:** A data controller must be accountable for complying with these principles. Example: a hospital appointing a Data Protection Officer responsible for compliance.

Together, FIPPs and the OECD Guidelines form the conceptual basis for laws such as GDPR, HIPAA, and CCPA discussed below.

Q2. Compare GDPR, HIPAA, and CCPA in terms of scope, applicability, and key provisions. (6 Marks)

GDPR, HIPAA, and CCPA are major legal frameworks that regulate how organisations collect, process, and protect personal data, each with a different scope and jurisdiction.

Aspect	GDPR	HIPAA	CCPA
Region	European Union (and any organisation processing EU residents' data)	United States (federal law)	California, United State (state law)
Scope/applicability	All personal data of EU residents, across all sectors	Protected Health Information (PHI) held by healthcare providers, insurers, and their partners	Personal data of California consumers collected by qualifying businesses
Key provisions	Right to access, rectify, erase ("right to be forgotten"), data portability, breach notification within 72 hours	Privacy Rule and Security Rule governing use/disclosure of health data; mandatory safeguards and breach notification	Right to know what data is collected, right to delete, right to opt out o the sale of personal data
Penalties	Up to €20 million or 4% of global annual turnover	Civil and criminal penalties, including fines per violation	Civil penalties per violation, with statutory damages for data breach

Key takeaway: GDPR is the broadest and strictest, applying to all personal data across sectors; HIPAA is sector-specific to healthcare; and CCPA is consumer-rights focused, giving California residents control over the sale of their data.

Q3. Explain data anonymization and pseudonymization techniques with real-world examples. How do they differ? (6 Marks)

Anonymization

Meaning: The process of irreversibly removing or altering personally identifiable information so that an individual can no longer be identified, even by the data controller.

Example: A hospital publishes a research dataset where patient names, addresses, and ID numbers are permanently removed and ages are generalised into ranges (e.g. 30–40), making re-identification effectively impossible.

Common techniques: Generalisation (replacing precise values with ranges), suppression (removing fields entirely), noise addition, and aggregation.

Pseudonymization

Meaning: The process of replacing identifying fields with artificial identifiers (pseudonyms), while keeping a separately stored mapping that allows re-identification if needed under controlled conditions.

Example: A bank replaces customer names in a fraud-analytics dataset with tokens like "CUST_00231"; the mapping between tokens and real identities is kept securely separate and used only when legally required.

Common techniques: Tokenization, encryption of identifiers, and hashing with a securely managed key.

Key Difference

Anonymization is irreversible — once applied, the original identity cannot be recovered, and GDPR no longer treats such data as personal data. Pseudonymization is reversible under controlled conditions, so GDPR still treats pseudonymised data as personal data requiring protection, though it reduces risk if a breach occurs.

Q4. Explain K-anonymity, L-diversity, and T-closeness with suitable examples. Discuss the limitations of K-anonymity that L-diversity and T-closeness address. (6 Marks)

K-anonymity

Meaning: A dataset satisfies k-anonymity if each record is indistinguishable from at least k-1 other records with respect to a set of quasi-identifiers (e.g. age, ZIP code, gender).

Example: If a hospital dataset is 5-anonymous, any combination of age and ZIP code matches at least 5 patient records, so no single patient can be uniquely pinpointed just from those fields.

Limitation: K-anonymity protects identity but not sensitive attribute values — if all k records in a group share the same diagnosis, an attacker still learns that sensitive value with certainty (a homogeneity attack).

L-diversity

Meaning: Extends k-anonymity by requiring each equivalence class (group of indistinguishable records) to contain at least L well-represented distinct values for the sensitive attribute.

Example: In a 5-anonymous group of patients, l-diversity requires at least 3 different diagnoses to appear, so an attacker cannot conclude a specific patient's condition with certainty.

Limitation: L-diversity does not account for the overall distribution of sensitive values — if 90% of a group has the same rare disease, technically diverse values may still leak strong probabilistic information (a skewness attack).

T-closeness

Meaning: Further refines l-diversity by requiring the distribution of a sensitive attribute within each equivalence class to be close (within threshold t) to its distribution in the overall dataset.

Example: If 10% of the overall dataset has a certain condition, t-closeness ensures each anonymised group also reflects roughly that same 10% proportion, rather than a skewed concentration.

Model	Protects Against	Key Limitation Addressed
K-anonymity	Direct re-identification via quasi-identifiers	Ignores diversity of sensitive attribute values
L-diversity	Homogeneity attacks (same sensitive value repeated)	Ignores overall distribution/skewness of values
T-closeness	Skewness and attribute-disclosure attacks	Reduces utility more, since it constrains distributions tightly

Q5. What is differential privacy? Explain its working principle and discuss its application in analytics with a real-world example. (6 Marks)

Meaning: Differential privacy is a mathematical framework that guarantees the output of a data analysis is nearly the same whether or not any single individual's data is included in the dataset, so an observer cannot determine whether a specific person's data was used, or infer anything about that person from the result.

Formal idea: A randomised algorithm satisfies ε-differential privacy if, for any two datasets differing in exactly one record, the probability of any given output changes by at most a factor of e^ε. A smaller ε means the two outputs must be nearly indistinguishable, giving stronger privacy; a larger ε allows more variation, giving weaker privacy but more accurate results.

Working Principle

- **Calibrated noise addition:** Random statistical noise (commonly drawn from a Laplace or Gaussian distribution) is added to query results or to individual data points. The amount of noise is calibrated to the "sensitivity" of the query — how much a single record could change the result — so that individual contributions are masked without destroying overall patterns.
- **Privacy budget (ε):** Each query consumes part of a total "privacy budget." Answering many queries on the same dataset gradually erodes privacy, so systems track cumulative ε spent and stop answering, or add proportionally more noise, once the budget is exhausted.
- **Global (centralised) model:** Raw data is collected by a trusted curator (e.g. a company's central server), which adds noise only when releasing query results or

statistics. This preserves more accuracy per unit of privacy but requires users to trust the central server with their raw data.

- **Local model:** Noise is added on each individual's own device before any data leaves it, so even the collecting server never sees true raw values. This removes the need to trust a central party but typically requires more noise (and hence less accuracy) to achieve the same privacy guarantee.
- **Composition property:** Differential privacy guarantees compose predictably — running several differentially private analyses on the same data has a combined, quantifiable privacy cost, which lets system designers reason mathematically about cumulative risk rather than guessing.

Application in Analytics — Real-World Examples

US Census Bureau (global model): For the 2020 Census, the Bureau applied differential privacy to published population counts and demographic tables, adding carefully calibrated noise so that no individual respondent's household could be reconstructed from cross-referencing multiple published tables, while still providing statistically reliable counts for federal funding and redistricting decisions.

Apple (local model): Apple applies local differential privacy on-device to collect usage data such as popular emoji, typing patterns for QuickType suggestions, and Safari browsing statistics, adding noise before any data leaves the user's phone, so Apple's servers only ever see privatised, aggregate-safe signals.

Google (RAPPOR): Google uses a local differential privacy mechanism called RAPPOR in Chrome to collect statistics such as default homepage settings and software configurations, allowing it to spot trends (e.g. malware hijacking browser settings) across millions of users without identifying any individual.

Advantages and Limitations

- **Advantage:** Provides a mathematically provable, quantifiable privacy guarantee rather than a best-effort heuristic, and remains robust even against attackers with unlimited external/auxiliary information.
- **Limitation:** There is an inherent trade-off between privacy (smaller ε) and accuracy (utility) of results; very strong privacy guarantees can make results too noisy to be useful for small datasets or rare events.

Q6. (Case-based/Application) A retail company wants to publish anonymized customer purchase data for research while complying with GDPR. Suggest appropriate anonymization techniques and privacy models it should apply, and explain the privacy-utility trade-off it may face. (6 Marks)

Scenario: A retail company wants to publish anonymised customer purchase data for external research while remaining compliant with GDPR.

Privacy Risks in This Scenario

- **Re-identification via quasi-identifiers:** Fields like ZIP code, date of birth, and gender, though not directly identifying on their own, can be combined with public records (e.g. voter rolls) to uniquely re-identify individuals — studies show over 85% of the US population can be identified this way.
- **Sensitive attribute disclosure:** Purchase history can reveal sensitive information such as pregnancy, health conditions, or religious practices, even if the customer's name is removed, simply from the pattern of items bought.
- **Linkage attacks across releases:** If the company publishes multiple datasets over time (e.g. monthly), an attacker can cross-reference releases to narrow down or confirm an individual's identity, even if each release alone looks safely anonymised.
- **GDPR non-compliance risk:** Under GDPR, data is only exempt from regulation if it is truly and irreversibly anonymised; if re-identification remains reasonably possible, the data is still classified as "personal data" and the company remains liable for its protection.

Recommended Techniques and Privacy Models

- **1. Remove direct identifiers:** Strip names, email addresses, phone numbers, and loyalty card numbers entirely at the outset, since GDPR requires true anonymisation (not just pseudonymisation) for data to fall outside its scope.
- **2. Apply k-anonymity on quasi-identifiers:** Generalise fields like ZIP code (e.g. to the first 3 digits) and age (e.g. into 10-year bands) so that each combination of quasi-identifiers matches at least k customers (e.g. k=10), preventing re-identification through cross-referencing with external data.
- **3. Apply l-diversity / t-closeness on purchase categories:** Within each anonymised group, ensure a diverse and representative spread of purchase categories so that sensitive buying patterns (e.g. health-related or baby products) cannot be inferred with high confidence for any individual in that group.
- **4. Use differential privacy for aggregate/statistical releases:** If the research only needs aggregate insights (e.g. "total sales of category X by region"), publish results through a differentially private mechanism instead of releasing row-level data, giving a mathematically provable privacy guarantee with no need for record-level anonymisation at all.
- **5. Restrict and monitor repeated releases:** Track a cumulative "privacy budget" across multiple data releases over time and avoid publishing overlapping datasets that could enable linkage attacks between releases.

- **6. Data minimisation:** Include only the fields genuinely needed for the research (e.g. exclude exact transaction timestamps or store location if not required), reducing the overall risk surface before any anonymisation is even applied.

Privacy–Utility Trade-off

Every anonymisation choice the company makes trades off privacy strength against how useful the data remains for researchers:

Choice	Effect on Privacy	Effect on Utility
Larger k in k-anonymity (e.g. k=50 vs k=5)	Stronger — harder to isolate any individual	Weaker — more generalisation blurs fine-grained patterns (e.g. broader ZIP regions)
Smaller ε in differential privacy	Stronger — output barely changes with/without any one person	Weaker — more noise added, so small subgroups or rare events become less reliable
Stricter t-closeness threshold	Stronger — group distributions closely match overall population	Weaker — may force merging of dissimilar records, losing category-level detail

For example, generalising ZIP codes to broad regions protects privacy well but makes location-based research (e.g. "which neighbourhoods buy the most organic food") far less precise. Similarly, adding differential privacy noise protects against re-identification but can make sales figures for a small or niche product category unreliable. The company must therefore choose parameters (k, l, t, ε) that satisfy GDPR's anonymisation standard while still leaving enough analytical value for the intended research — often by involving both a data protection officer and the research team when setting these thresholds, and testing candidate releases against real re-identification attempts before publishing.